

Scallop

Audit Report

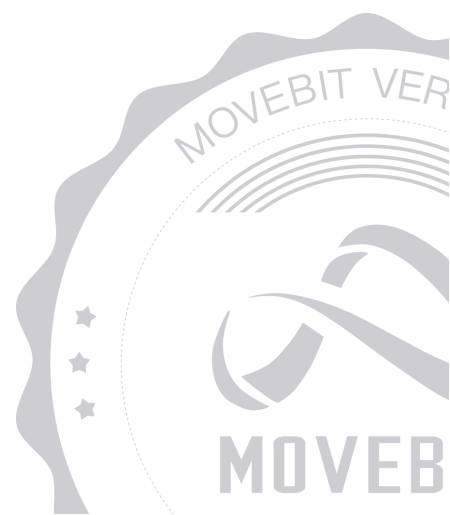


contact@bitslab.xyz



https://twitter.com/movebit_

Mon Nov 24 2025



Scallop Audit Report

1 Executive Summary

1.1 Project Information

Description	The Scallop Lending Protocol is a decentralized lending protocol that allows users to lend and borrow crypto assets,The protocol is built on the SUI blockchain and is completely open-source,The protocol is designed to be simple, efficient, and secure,Moreover, the protocol is designed to be composable, meaning that other protocols can easily integrate with it,The guide will walk you through the process of integrating with the Scallop Lending Protocol
Type	DeFi
Auditors	Alex,hyer,Light
Timeline	Thu Nov 06 2025 - Mon Nov 24 2025
Languages	Move
Platform	Sui
Methods	Architecture Review, Unit Testing, Manual Review
Source Code	https://github.com/scallop-io/sui-lending-protocol
Commits	7b79e175099b6d485955551903e717b79aa8ed4015f165b033eaae8b31059847e49afe0a25b8273a

1.2 Files in Scope

The following are the SHA1 hashes of the original reviewed files.

ID	File	SHA-1 Hash
MOV1	contracts/query/Move.toml	ad34d3c19d0a32a7c528bc47e032d05fe76a717c
MQU	contracts/query/sources/market_query.move	b6c994379df8e1a5332488dd1d6835e0163d5638
OQU	contracts/query/sources/obligation_query.move	9cd47aee74bcc3100f6bcf4b91ab0610e38d5b57
MMA5	contracts/sui_x_oracle/x_oracle/Move.mainnet.toml	2a264f8324f43291c4546f659c6bdea5a63abe59
XOR	contracts/sui_x_oracle/x_oracle/sources/x_oracle.move	275f4200e0e5095dce0e5f3f74bd6cbd1daf8d61
PFE	contracts/sui_x_oracle/x_oracle/sources/price_feed.move	45d1525ee62026419acae6c5d48942c481e9cd39
PUP	contracts/sui_x_oracle/x_oracle/sources/price_update_policy.move	5068ae842c08090416afe0c88ab251fcd5745930
MOV10	contracts/sui_x_oracle/pyth_rule/Move.toml	2b04c8403186d45c4885860bb85a11ba49406045
RUL5	contracts/sui_x_oracle/pyth_rule/sources/rule.move	18da13446440a24140209b326bd65b9fdf0cf6db
MOV11	contracts/protocol/Move.toml	36e5a66a7bbad2e7b0b589a74d4adda7599500de

OBL	contracts/protocol/sources/obligation/obligation.move	8f14dd510491700a37a6a368103faed2b7ac3c02
ODE	contracts/protocol/sources/obligation/obligation_debts.move	4479481ea5a9fb8d02ced63a2c899703674cbbce
OAC	contracts/protocol/sources/obligation/obligation_access.move	8fba34c523d56953be636da363a0217f9685026d
OCO2	contracts/protocol/sources/obligation/obligation_collaterals.move	e099937644ba8a15ccc0913a45ad8f317fb68ff2
MDK	contracts/protocol/sources/market/market_dynamic_keys.move	b654404455b50066d280d840aa25e4ab2f8c366a
BDY	contracts/protocol/sources/market/borrow_dynamics.move	16fb9b3e8462296db229f86d596d5fac112ffa4f
CST	contracts/protocol/sources/market/collateral_stats.move	221851b3afc80eee227585600f44e4a10749b527
RES	contracts/protocol/sources/market/reserve.move	58fe963a3c85419427dcf7817264c8d9b084b97f
IRE	contracts/protocol/sources/market/incentive_rewards.move	4b59776b7e0d76121877ff057ae103533822363a
RMO1	contracts/protocol/sources/market/risk_model.move	7e906597e12aece695117244422e1b2b5e03a2f6
AAS	contracts/protocol/sources/market/asset_active_state.move	19d3d7ec19ff8f5b09aa1f5678603e47dfb07560
IMO1	contracts/protocol/sources/market/interest_model.move	cfbd9f17d16c1ae796b56663346df13d2a4bee19

LIM	contracts/protocol/sources/market/limiter.move	7d8658618d295f384f98c2ca3f435b2156690bcf
BRE	contracts/protocol/sources/referral/borrow_referral.move	3c10882b32bf9efb41f80e95ed24f99e07a69f13
APP	contracts/protocol/sources/app/app.move	c69ba208577c96251daa5ffc32c26c2de39b5228
PRI1	contracts/protocol/sources/evaluator/price.move	31a50a55710487bcdd0c685dad8d71c88cc2df66
CVA1	contracts/protocol/sources/evaluator/collateral_value.move	85ff554b4a28e6f73b23e060ef942570f71bd59
VCA	contracts/protocol/sources/evaluator/value_calculator.move	4e76328829326e750dc1c9d28a7875433ccc4ab3
BWE	contracts/protocol/sources/evaluator/borrow_withdraw_evaluator.move	2707f57e2dd7d2d0efe2584ad92415655158a6cb
LEV	contracts/protocol/sources/evaluator/liquidation_evaluator.move	779778ad5df560b657ab4fa2ef72523144338d98
DVA	contracts/protocol/sources/evaluator/debt_value.move	fb0fe747f1a59d5803be546657b3d2866ea7096d
CVE	contracts/protocol/sources/version/current_version.move	64cf5ff2846b9ac51e13421da61227f3ea531f60
VER	contracts/protocol/sources/version/version.move	81f61865751f08cccd434b23dbadfdf0d6205521
OOB1	contracts/protocol/sources/user/open_obligation.move	776b938c7d61f589e3d221f1c5c1f476ed1f57b3

REP	contracts/protocol/sources/user/repay.move	0923341bf3a5ec4e5d61a744ee46f34d17f1ec4b
MIN	contracts/protocol/sources/user/mint.move	aa58fe114400a60805d8115df31d726a3d72a552
WCO	contracts/protocol/sources/user/withdraw_collateral.move	922e9c47e916d00a29c969a5fd0234721a4bac80
LOB	contracts/protocol/sources/user/lock_obligation.move	e3c87959fad783c37c530e4783a1972d006fa6c5
RED	contracts/protocol/sources/user/redeem.move	67b81223f830ee4172b306d16712cc4448278389
LIQ	contracts/protocol/sources/user/liquidate.move	65269c344aaef38c0f700f107ed4dad1547f155
AIN	contracts/protocol/sources/user/accrue_interest.move	b76674864b4120bb2c194de54b68fb234b9fa89a
FLO	contracts/protocol/sources/user/flash_loan.move	e27b4ea31e4dd1b50a3c8ca87f0ce4320030de4e
DCO	contracts/protocol/sources/user/deposit_collateral.move	6be09824426028228113459674f8545e3fadea4b
MOV12	contracts/protocol_whitelist/Move.toml	8c04760c6762854fd95f4bf65b92a9d553772167
PWH	contracts/protocol_whitelist/sources/protocol_whitelist.move	ba53fec032682339e6d2830e8caf571a62c7d62b
APM	contracts/protocol/sources/market/apm.move	dbdacee7186ab90d470d2a9379ba2d370d1ca691

MAR	contracts/protocol/sources/market/market.move	bcac564174f184c16b532481490ee6319a5c241f
BOR	contracts/protocol/sources/user/borrow.move	4d9c07cba056fd8aa3004108a212393c38ce6ceb

1.3 Issue Statistic

Item	Count	Fixed	Acknowledged
Total	6	4	2
Critical	0	0	0
Major	0	0	0
Medium	0	0	0
Minor	4	2	2
Informational	2	2	0

1.4 MoveBit Audit Breakdown

MoveBit aims to assess repositories for security-related issues, code quality, and compliance with specifications and best practices. Possible issues our team looked for included (but are not limited to):

- Transaction-ordering dependence
- Timestamp dependence
- Integer overflow/underflow by bit operations
- Number of rounding errors
- Denial of service / logical oversights
- Access control
- Centralization of power
- Business logic contradicting the specification
- Code clones, functionality duplication
- Gas usage
- Arbitrary token minting
- Unchecked CALL Return Values
- The flow of capability
- Witness Type

1.5 Methodology

The security team adopted the "**Testing and Automated Analysis**", "**Code Review**" and "**Formal Verification**" strategy to perform a complete security test on the code in a way that is closest to the real attack. The main entrance and scope of security testing are stated in the conventions in the "Audit Objective", which can expand to contexts beyond the scope according to the actual testing needs. The main types of this security audit include:

(1) Testing and Automated Analysis

Items to check: state consistency / failure rollback / unit testing / value overflows / parameter verification / unhandled errors / boundary checking / coding specifications.

(2) Code Review

The code scope is illustrated in section 1.2.

(3) Formal Verification(Optional)

Perform formal verification for key functions with the Move Prover.

(4) Audit Process

- Carry out relevant security tests on the testnet or the mainnet;
- If there are any questions during the audit process, communicate with the code owner in time. The code owners should actively cooperate (this might include providing the latest stable source code, relevant deployment scripts or methods, transaction signature scripts, exchange docking schemes, etc.);
- The necessary information during the audit process will be well documented for both the audit team and the code owner in a timely manner.

2 Summary

This report has been commissioned by [Scallop](#) to identify any potential issues and vulnerabilities in the source code of the [Scallop](#) smart contract, as well as any contract dependencies that were not part of an officially recognized library. In this audit, we have utilized various techniques, including manual code review and static analysis, to identify potential vulnerabilities and security issues.

During the audit, we identified 6 issues of varying severity, listed below.

ID	Title	Severity	Status
APM-1	Unused <code>curr_index</code> Index in <code>is_price_fluctuate</code>	Informational	Fixed
APM-5	Use <code>type_name::with_defining_ids()</code> Instead of <code>type_name::get()</code>	Minor	Fixed
APP-2	Disabled Functions Still Callable	Minor	Acknowledged
BRE-6	Use <code>public(package)</code> Instead of <code>public(friend)</code>	Minor	Acknowledged
OCO-3	Missing Event Emission	Informational	Fixed
PRE-9	Lacks a Separate Delete Function	Minor	Fixed

3 Participant Process

Here are the relevant actors with their respective abilities within the [Scallop](#) Smart Contract :

Admin:

- `set_apm_threshold`: Sets the price fluctuation threshold percentage for a given market and asset, defining how much the price must rise to trigger APM.
- `extend_interest_model_change_delay` Extends the delay period before an interest model change becomes active.
- `extend_risk_model_change_delay` Extends the activation delay for risk model changes.
- `extend_limiter_change_delay` Extends the activation delay for limiter configuration updates.
- `create_interest_model_change` Creates a proposal to change the interest model for a specific market.
- `add_interest_model` Registers a new interest model into the system.
- `update_interest_model` Updates an existing interest model configuration.
- `create_risk_model_change` Creates a proposal to update the risk model for a given market.
- `add_risk_model` Adds a new risk model to the configuration registry.
- `update_risk_model` Updates parameters of an existing risk model.
- `add_limiter` Registers a limiter (rate limiter) for controlling borrow or supply limits.
- `create_limiter_params_change` Creates a proposed update to limiter parameters.
- `create_limiter_limit_change` Creates a proposal to update limiter limits.
- `apply_limiter_limit_change` Applies pending limiter limit updates after delay expiration.

- `apply_limiter_params_change` Applies pending limiter parameter updates after delay expiration.
- `set_apm_threshold` Sets the price fluctuation threshold for triggering APM on specified markets.
- `init_market_coin_price_table`: Initializes market coin-price mapping table.
- `add_whitelist_address` Adds an address to the protocol whitelist.
- `remove_whitelist_address` Removes an address from the whitelist.
- `disable_borrow` Disables borrowing for a specific market.
- `disable_collateral` Disables using a specific market's asset as collateral.
- `set_flash_loan_fee` Sets the fee rate for flash loans.
- `take_revenue` Transfers accumulated protocol revenue to the admin-controlled address.
- `take_borrow_fee` Withdraws collected borrow fees from the market.
- `update_borrow_fee` Updates the borrow fee configuration for a market.
- `update_borrow_fee_recipient` Deprecated; aborts on use.
- `update_supply_limit` Updates the maximum allowed supply for a given asset.
- `update_min_collateral_amount` Updates the minimum amount of collateral required per market.
- `update_borrow_limit` Updates the borrowing limit configuration for an asset.
- `update_isolated_asset_status` Updates the isolation status for an asset .
- `add_lock_key` Registers a new lock key that can modify obligations.
- `remove_lock_key` Removes an existing lock key from the system.
- `add_reward_key` Adds a reward-distribution authorization key.
- `remove_reward_key` Removes an existing reward key.

- `create_referral_witness_list` Creates a new witness list for referral authorization.
- `add_referral_witness_list` Adds a witness to the referral authorization list.
- `remove_referral_witness_list` Removes a witness from the referral list.
- `set_base_asset_active_state` Activates or deactivates a base asset in the market.
- `set_collateral_active_state` Activates or deactivates an asset's use as collateral.

User:

- `refresh_apm_state:` Refreshes the APM state for a given asset by recording the current hour's minimum price; callable by anyone.
- `create_borrow_referral` : Creates a BorrowReferral object with custom discount and referral share, if the user holds an authorized witness.
- `destroy_borrow_referral:` Destroys a BorrowReferral object and retrieves its stored referral fee balance.
- `add_referral_cfg:` Adds a custom configuration entry to a BorrowReferral via dynamic field.
- `remove_referral_cfg:` Removes a custom configuration entry from the referral object.

4 Findings

APM-1 Unused `curr_index` Index in `is_price_fluctuate`

Severity: Informational

Status: Fixed

Code Location:

contracts/protocol/sources/market/apm.move#75

Descriptions:

```
public(friend) fun is_price_fluctuate(
    market: &Market,
    x_oracle: &XOracle,
    type_name: TypeName,
    clock: &Clock,
): bool {
    let vect = df::borrow<MinPriceHistoryKey, vector<MinPriceHistory>>
(market::uid(market), min_price_history_key(type_name));
    let min_price_in_24h = decimal::from(0);

    let now = clock::timestamp_ms(clock) / 1000;
    let curr_index = (now / 3600) % 24; // hourly index

    let i = 0;
```

The variable `curr_index` is calculated but never used anywhere in the subsequent logic.

Suggestion:

It is recommended to remove the `curr_index` calculation .

Resolution:

This issue has been fixed. The client has adopted our suggestions.

APM-5 Use `type_name::with_defining_ids()` Instead of `type_name::get()`

Severity: Minor

Status: Fixed

Code Location:

contracts/protocol/sources/market/apm.move#35

Descriptions:

In the `refresh_apm_state()` function, the protocol obtains the coin type using `type_name::get()` .

```
public fun refresh_apm_state<T>(  
    version: &Version,  
    market: &mut Market,  
    x_oracle: &XOracle,  
    clock: &Clock,  
    _ctx: &mut TxContext  
) {  
    // check if version is supported  
    version::assert_current_version(version);  
  
    let coin_type = type_name::get<T>();  
  
    // record the price history  
    record_min_price_history(  
        market,  
        x_oracle,  
        coin_type,  
        clock,  
    );  
}
```


However, this method is **deprecated**. It is now recommended to use

`type_name::with_defining_ids()` instead.

https://github.com/MystenLabs/sui/blob/main/crates/sui-framework/packages/move-stdlib/sources/type_name.move#L133-L138

Suggestion:

It is recommended to use `type_name::with_defining_ids()` instead.

Resolution:

This issue has been fixed. The client has adopted our suggestions.

APP-2 Disabled Functions Still Callable

Severity: Minor

Status: Acknowledged

Code Location:

contracts/protocol/sources/app/app.move#56,84,94,104

Descriptions:

The `REASONABLE_MAX_DELAYS` and the functions `extend_interest_model_change_delay` , `extend_risk_model_change_delay` , and `extend_limiter_change_delay` related to delay extensions have been disabled, but they can still be called. Please confirm whether these functions will be re-enabled in future updates before deployment, or if they are intended to be completely deprecated.

Suggestion:

Please confirm whether these functions will be re-enabled in future updates before deployment, or if they are intended to be completely deprecated.

BRE-6 Use `public(package)` Instead of `public(friend)`

Severity: Minor

Status: Acknowledged

Code Location:

contracts/protocol/sources/referral/borrow_referral.move#287

Descriptions:

In the `borrow_referral` module, the protocol extensively uses the `friend` function.

```
public(friend) fun add_witness<Witness: drop>(
  authorized_witness_list: &mut AuthorizedWitnessList,
) {
  let witness_type = type_name::get<Witness>();
  if (vec_set::contains(&authorized_witness_list.witness_list, &witness_type) == false) {
    vec_set::insert(
      &mut authorized_witness_list.witness_list,
      witness_type
    );
  }
}
```

However, the `friend` function has been deprecated, and the recommended approach is to use **packages** instead. <https://docs.sui.io/guides/developer/advanced/move-2024-migration>

```
public(package)
friend declarations and the associated public(friend) visibility modifiers are deprecated.
In their place is the public(package) visibility modifier, which allows calling functions only
within the same package where they are defined.
```

Suggestion:

It is recommended to use `public(package)` instead of `public(friend)`

Resolution:

This issue has been fixed. The client has adopted our suggestions.

OCO-3 Missing Event Emission

Severity: Informational

Status: Fixed

Code Location:

contracts/sui_x_oracle/custom_afsui_rule/sources/oracle_config.move#69-103;

contracts/sui_x_oracle/custom_hasui_rule/sources/oracle_config.move#69-103

Descriptions:

In the `update_oracle_config` and `update_exchange_rate_constraint` functions of these two contracts, the contract updates critical parameters of OracleConfig but does not emit any events within the functions.

Suggestion:

It is recommended to add event emission.

Resolution:

This issue has been fixed. The client has adopted our suggestions.

PRE-9 Lacks a Separate Delete Function

Severity: Minor

Status: Fixed

Code Location:

contracts/sui_x_oracle/pyth_rule/sources/pyth_registry.move#62-79

Descriptions:

The existing code can only overwrite an existing feed but cannot remove it independently.

Suggestion:

It is recommended to add a dedicated removal function.

Resolution:

This issue has been fixed. The client has adopted our suggestions.

Appendix 1

Issue Level

- **Informational** issues are often recommendations to improve the style of the code or to optimize code that does not affect the overall functionality.
- **Minor** issues are general suggestions relevant to best practices and readability. They don't post any direct risk. Developers are encouraged to fix them.
- **Medium** issues are non-exploitable problems and not security vulnerabilities. They should be fixed unless there is a specific reason not to.
- **Major** issues are security vulnerabilities. They put a portion of users' sensitive information at risk, and often are not directly exploitable. All major issues should be fixed.
- **Critical** issues are directly exploitable security vulnerabilities. They put users' sensitive information at risk. All critical issues should be fixed.

Issue Status

- **Fixed:** The issue has been resolved.
- **Partially Fixed:** The issue has been partially resolved.
- **Acknowledged:** The issue has been acknowledged by the code owner, and the code owner confirms it's as designed, and decides to keep it.

Appendix 2

Disclaimer

This report is based on the scope of materials and documents provided, with a limited review at the time provided. Results may not be complete and do not include all vulnerabilities. The review and this report are provided on an as-is, where-is, and as-available basis. You agree that your access and/or use, including but not limited to any associated services, products, protocols, platforms, content, and materials, will be at your own risk. A report does not imply an endorsement of any particular project or team, nor does it guarantee its security. These reports should not be relied upon in any way by any third party, including for the purpose of making any decision to buy or sell products, services, or any other assets. TO THE FULLEST EXTENT PERMITTED BY LAW, WE DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, IN CONNECTION WITH THIS REPORT, ITS CONTENT, RELATED SERVICES AND PRODUCTS, AND YOUR USE, INCLUDING BUT NOT LIMITED TO THE IMPLIED WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE, NOT INFRINGEMENT.

